
UNIT 4 CYBERSECURITY STANDARDS AND POLICIES

Structure

- 4.0 Introduction
- 4.1 Learning Outcomes
- 4.2 Defining Critical Terms
 - 4.2.1 Policy
 - 4.2.2 Procedure
 - 4.2.3 Standard
 - 4.2.4 Guideline
 - 4.2.5 Controls
 - 4.2.6 Metric
- 4.3 Defining Cybersecurity Standards
- 4.4 Different Cybersecurity Standards
 - 4.4.1 ISO series
 - 4.4.2 PCI DSS
 - 4.4.3 HIPAA
 - 4.4.4 FINRA
 - 4.4.5 GDPR
- 4.5 Cybersecurity Policies
 - 4.5.1 Defining Cybersecurity Policy
 - 4.5.2 Importance of Security Policies
 - 4.5.3 Types of security policies
 - 4.5.4 Key elements in a security policy
 - 4.5.5 Examples of security policies
- 4.6 Let Us Sum Up
- 4.7 Check Your Progress: The Key

4.0 INTRODUCTION

Cybersecurity in the modern digital domain of Internet, including Users, Attackers, and practically everything else function differently in the present and extremely dynamic digital world. If something works in one direction, other things could presumably achieve the same thing by moving in a different direction. So the whole concept is that, even if the technique is different, things may still get the job done. In terms of cybersecurity, each party in the area believes in establishing its own set of rules, but because the Internet is used globally, there are a number of criteria that must be adhered to regardless of where the internet is utilized.

Cybersecurity standards are collections of best practices developed by professionals to assist companies defend themselves against cyber-attacks and strengthen their cybersecurity posture. All firms, regardless of size, industry, or sector, may benefit from cybersecurity frameworks. Regardless

of the size of the business or the industry or sector in which it operates, security guidelines are typically offered. This section contains details on each standard that is generally considered to be a necessary component of any cybersecurity plan.

4.1 LEARNING OUTCOMES

Some written guidelines are necessary to make Cybersecurity measures explicit across domains, locations, and for suppliers. Cybersecurity Standards are the name for these guidelines. These are general prescriptions for the best execution of certain actions. Methods, recommendations, reference frames, and other items may be included in the standards. It assures security efficiency, improves integration and interoperability, allows for meaningful measure comparisons, minimizes complexity, and provides the framework for future advancements. This unit discusses the various Cybersecurity Standards and Policies that are typically followed by information technology enabled organizations.

4.2 DEFINING CRITICAL TERMS

It has been observed that even experienced professional are often confused about the difference between a policy, procedure, standard and guideline. They tend to use these terms interchangeably or include them all in a single document. These concepts are different yet dependent on one another. Part of the management of any security programme is determining and defining how security will be maintained in the organisation. Ensuring proportionate policies, standards, guidelines and procedures are in place that are understood and consistently enforced is critical in any insider threat programme. They should provide clarity to the reader when dealing with accountability issues or activities that are of importance to the organisation. Knowing where a policy, standard, guideline or procedure is required should be defined by the role based risk assessment process.

This section discusses the differences between the concepts and how they fit together. This section talks about these concepts in the context of the internal documents for a specific organisation. It is not talking about public policy, Government policy, an insurance or funeral policy, or ISO standards for example.

4.2.1 Policy

Policies are high-level declarations of management intent from an organization's senior leadership, intended to influence choices and direct the business toward the desired objectives. To develop actionable and accountable requirements, policies are enforced by standards and further executed by processes. The IT security policy outlines the guidelines for everyone who accesses and utilizes the IT resources and assets of a company. An organization's IT assets and resources must be accessed and used in accordance with the policies laid out in its information technology (IT) security policy. An information security policy should: Protect all organizational end-to-end security procedures. Be realistic and enforceable. Be frequently updated in response to changing threats and business demands. Each policy should address a critical issue related to the attainment of the

organization's ultimate goal. As a result, a workplace health and safety policy emphasizes the importance of safety to the business and who the principles apply to. The policy must be in line with the strategic goals (such as improved IT detection rate, enhanced service quality, reduced costs, and fewer injuries). IT policy can be broken down into three aspects or components, namely:

- Policy decisions are decisions a governing body adopts in the organisation
- Policy statements are a written declaration of the policy decision
- Policy instruments are a document that contains either one or many policy statements.

When discussing policies, be aware of the many components since otherwise, it might get complicated. The King Code goes into great detail on how a governing body sets IT policies for any organization. A governing body determines the direction or strategy for how the organization should approach and handle an cybersecurity problem (via policy choices) and also authorizes security policy (in the form of a policy instrument) to carry out that direction. Cybersecurity Policies are developed for specific reasons and the audience as the target (typically the SOC Team), and use language that would be easily comprehended by them. IT security professionals often mix and match policies, procedures, guidelines, and standards, resulting in a policy that is either illogical or ineffective for its intended security goals. More information on the qualities of good security policies may be found here. Because policy reflects strategy, it is the most significant document.

A policy is a document that lays forth the conditions or regulations that must be followed. As a foundation for their existence, policies typically relate to standards or guidelines. A policy's scope is usually a wide, high-level declaration of aim. An Encryption Use Policy, for instance, may include something like encryption should be utilized under these conditions. Legal Services reviews all third-party contracts, for example, is an example of a policy that you will frequently see in businesses. In this case, the governing body has decided that legal services will analyze third-party contracts. Other than legal services, no other department in the organization has been authorized to analyze third-party contracts. As a result, a policy is required. Senior management produces and supports policies, which are official pronouncements. They might be system-wide, issue-specific, or organization-wide. Your company's security rules should mirror your information security program's goals, such as data protection, risk management, and infrastructure security. Your rules should be as a foundation for a structure; they should be long-lasting and resistant to change or erosion that is

- Driven by business objectives and conveying the amount of risk senior management is willing to accept.
- Easily accessible and understood by the intended reader
- Created with the intent to be in place for several years and regularly reviewed with approved changes made as needed.

4.2.2 Procedure

Procedures are a collection of procedures that must be followed to complete a cybersecurity measure or process following a relevant standard to protect their online clients, financial flow, and corporate data. These measures should be designed to reduce risks from a variety of sources, such as internet-based attacks, such as spyware or malware, user-generated vulnerabilities, such as passwords that are easy to guess or information that is lost, inbuilt system or software flaws and vulnerabilities, and the exploitation of system or software features. Cybersecurity Procedures can assist in determining how an organization implements a policy, regulation, or control. There can be no defensible evidence of proper care activities without recorded processes. Procedures are typically established and maintained by the IT Security process owner/asset custodian, but stakeholder review is anticipated to verify that applicable compliance standards are met. A procedure's output is meant to fulfill a specified control. IT Security Procedures are also known as control actions in some cases. Procedures define the procedures that must be followed to complete a recurrent activity or adhere to a policy (often in the form of a checklist). Step-by-step instructions or remarks indicating where something should go are examples of these methods. A process explains how to carry out or enforce a policy to personnel. Written instructions in logical numbered stages are commonly included in procedures. Instead of 'protocol,' some individuals say 'process,' 'practice,' or 'work practice.' They are nearly identical, but we prefer the term "process." Standard operating procedures, or SOPs, are commonly used in the public sector. Major cybersecurity measures are use of strong passwords, Making sure staff members can only access data and services for which they are authorized and responsible, Effective firewalls as gatekeeper between office systems and the insecure Internet, and monitoring for any intrusions.

Procedures describe how a policy, regulation, or guideline is followed to achieve its requirements. The scope of a procedure refers to the precise processes and procedures that need to be followed to execute a specified standard or guideline. Defining the methods necessary to install 3DES or AES encryption on your firewalls is an example of this. Procedures are required once again. Procedures are step-by-step instructions for accomplishing a certain objective or obligation. They are usually designed for internal departments and should follow tight change management procedures. Procedures can be created as needed. If your business decides to go this way, you'll need to have thorough and consistent documentation of the processes you're establishing:

- Often act as the 'cookbook' for staff to consult to accomplish a repeatable process.
- Installing operating systems, performing a system backup, granting access rights to a system, and setting up new user accounts are all examples of procedures.

4.2.3 Standard

Standards are legally binding standards for processes, activities, and configurations that are intended to meet Control Objectives. Standards are meant to be detailed and prescriptive, ensuring that systems, applications,

and processes are developed and run with proper cybersecurity and privacy safeguards in mind. A standard describes how certain technologies or setups should be used consistently. A third-party-issued standard is the other type of standard for example an industry body like ISO 27000 for example, or data protection requirements. Third-party rules such as professional rules or codes such as an association's code of conduct are frequently related with third-party standards.

A standard is a collection of standards that must be followed by everyone. They are usually system or technology specific. A standard's purpose is to set the standards for a certain technology or sector. For example, establishing Triple DES (3DES) or Advanced Encryption Standard as the sole allowed encryption methods (AES). A standard can also be defined as: The following typeface appears on all contracts: Arial font, font size 8, normal margin type. Standards are frequently used on their own and referred to in policies. The following sentence may appear in certain policies: "We apply the contract standard to examine our contracts." The policy relates to the standard in this case, and the standard helps the target audience comply with the policy. Most internal organizational standards are required, however whether a standard is mandatory or optional is determined by the policy that governs it. A voluntary or required third-party norm is possible. An organisation may elect or agree to make a voluntary third-party norm obligatory. Typically, the default position is that they are optional.

4.2.4 Guideline

For rules, standards, or processes, guidelines give broad direction as well as supplementary counsel and assistance. A guideline provides direction and additional information to the reader in order to assist the audience. Guidelines are suggested procedures based on industry-accepted security practices. When discretion is allowed, guidelines can assist supplement Standards. Unlike Standards, Guidelines allow users to interpret, implement, and use them with discretion or freedom. It will also help the policymaker describe the policy in simpler words to the policy audience. Many individuals confuse a guideline with a policy since they both include comparable information. The most significant distinction between the two is that a guideline is optional, but policy is always obligatory.

Guidelines are similar to standards, but they vary in that, unlike standards, they are only recommendations or suggestions that should be followed but are not mandated. In most circumstances, guidelines and standards can be used interchangeably. Another example of a guideline is: "Collect as much pertinent information about the transaction as possible before examining a contract." Find out what the parties consider to be the major dangers." One of our program's courses, titled "Having Good Policies in Place," provides an example of policy advice. A guideline is optional or voluntary. When precise criteria are not applicable, consumers are given guidelines. Guidelines are created to help simplify specific procedures based on best practices. By their very nature, guidelines should be subject to interpretation and not be followed to the letter as these are more general vs. specific rules, provide flexibility for unforeseen circumstances and should NOT be confused with formal policy statements.

4.2.5 Controls

Controls are technical, administrative or physical safeguards. Controls are the nexus used to manage risks through preventing, detecting or lessening the ability of a particular threat from negatively impacting business processes. Controls directly map to standards, since control testing is designed to measure specific aspects of how standards are actually implemented. Technical controls are mechanisms used to regulate operations to meet policy requirements. For example, an organization with a BYOD policy may incur additional risks due to potentially insecure messaging applications and user error. Security teams may implement technical controls to mitigate risk, including mobile device management or mobile application management software. Additional technical controls may include firewalls, authentication mechanisms or antimalware. Technical controls can be volatile, particularly in distributed environments where a hacker or even a determined user may find and exploit security gaps in technology. Managing and updating technical controls are crucial tasks for information security professionals.

4.2.6 Metric

Unlike trends and analytics, which are produced by comparing a baseline of two or more measures recorded over time, metrics give a “point in time” picture of precise, discrete measurements. Metric analysis is used to create analytics. Through the gathering, analysis, and reporting of pertinent performance-related data, analytics are aimed to aid decision-making, evaluate performance, and increase accountability. Smart metrics are the best metrics, they are: Specific, Measurable, Attainable, Repeatable, and Time-dependent. Policies cover entire organization, whereas procedures focus on specific activities. Both have a role in the day-to-day operations of the business and employee success. Because these principles are so crucial as staff understand company’s rules and processes, as well as when to use them. Policy and procedure software can assist employee with this. Staff will always have access to the information they need, when they need it, if we save your files on the cloud. When it comes to policy and procedure creation, they provide a workflow feature that allows you to put documents through a thorough review process, with all of your reviewers providing feedback and allowing you to quickly transmit a new version after adjustments have been accepted.

After a policy or process has been adopted, this may assist in communicating it to the appropriate audience. After all, not every office or group will need to know the proper inventory technique, and it will save your staff time not having to wade through documents that do not apply to them. Version control will help your constantly updated and upgrading processes since your staff will always open the most recent procedure document. One can be confident that personnel are not following out-of-date procedures. The opportunity to assess your employees’ comprehension is one of the most crucial aspects. You may give employees exams to take after they’ve read a paper to ensure they’ve fully absorbed the material. This is a great way to promote communication and inefficiency within your company while also ensuring compliance. Another aspect that aids compliance is tracking, which informs administrators of who has read, tested, and passed the policy

or procedure, as well as who has not accomplished those responsibilities. The IT staff may then use the automated reminder tool, which increases in frequency as the activity is left undone, or escalate the task up the employee management tree.

Check Your Progress 1

Note: a) Space is given below for writing your answer.

b) Compare your answers with the ones given at the end of this Unit.

Describe Policy, Procedure, and Standard.

.....

.....

.....

.....

.....

4.3 DEFINING CYBERSECURITY STANDARDS

A Security Standard, by definition, is a published specification that provides a common language, has a technical specification or other specified criteria, and is intended to be applied consistently as a rule, guideline, or definition. The purpose of security standards is to make information technology (IT) systems, networks, and critical infrastructures more secure. The Well-Written Cybersecurity Standards promote uniformity among product creators and provide a trustworthy benchmark for security product purchases. A cybersecurity standard can be characterized as a collection of regulations that an organisation must follow in order to obtain permission to do certain tasks, such as take online payments or store medical data. The standards are a set of basic guidelines that an organisation must follow in order to remain compliant with any of the cybersecurity standards. There are various distinct standards that a company or organisation can choose from to introduce particular capabilities, depending on their needs. In certain locations, the government has its own set of rules that anybody wishing to work for the government must follow.

Cybersecurity standards may also be defined as a set of policies that must be implemented in the system to ensure that any standard is met. For example, if a company wants to take online payments, it must adhere to the PCI DSS standard. Some severe regulations that come under this compliance must be followed by the company in order to be qualified to accept online payments. Their system must be up to date, devoid of vulnerabilities, and they must provide network reports on a regular basis, among other requirements outlined in the standards. If the company can give healthy reports, they should be allowed to take online payments; otherwise, they will be unable to request payment through their web interface.

4.4 DIFFERENT CYBERSECURITY STANDARDS

There are several cybersecurity standards that are supposed to protect the system and its users in various ways. We have also discussed in brief in course four (MSE-025) of your programme. Based on what kind of data has to be protected, there are different standards. Below are some of the common and important standards:

4.4.1 ISO series

ISO is a common standard that organizations must follow in order to create an information security management system. It is made up of a collection of procedures that spell out the rules and conditions that must be met in order for an organization to be certified to this standard. According to this standard, the business must keep all technology up to date, servers must be free of vulnerabilities, and the organisation must be audited at the prescribed intervals to remain compliant. It is an international standard, and every organisation that provides services to other organizations that follow this standard is required to follow the ISMS policy outlined in ISO 27001 practice. ISO For all companies that hold and manage private information, security controls are an integral aspect of information security management. Although each organization's exact requirements for managing information security will differ, companies can use common measures to safeguard their data and satisfy their legal and contractual duties. When choosing and implementing security measures, businesses should follow Clause 6.1.2 of ISO 27001, which outlines a risk management methodology. ISO states that the risk assessment process must:

- Establish and maintain certain information security risk criteria.
- Ensure that repeated risk assessments 'produce consistent, valid and comparable results'.
- Identify risks associated with the loss of confidentiality, integrity and availability for information within the scope of the information security management system.
- Identify the owners of those risks.
- Analyze and evaluate information security risks according to specific criteria.
- Be documented.

The International Organization for Standardization (ISO) is a global standardization organisation. Things work because of international standards. To assure quality, safety, and efficiency, these standards establish a world-class specification for goods, services, and systems. They play an important role in international trade. On 23rd February; 1947, the ISO standard was formally created. It is a non-governmental multinational organisation that is independent. It now includes 162 national standards organizations and 784 technical committees and subcommittees to oversee the production of standards. Over 22336 International Standards and related publications have been produced by ISO, spanning practically every area from information technology to agriculture, food safety, and healthcare.

The International Organization for Standardization and the International Electro-technical Commission established the ISO series of information security standards to provide an internationally recognized foundation for effective information security management. It assists the firm in safeguarding information assets such as personnel information, financial data, and intellectual property. The necessity for the ISO 27000 series derives from the organization's vulnerability to cyber-attacks. Hackers are becoming a continual menace to every sector that employs technology as cyber-attacks become more common. The ISO 27000 series can be categorized into many types as mentioned below.

- **ISO 27001:** This standard enables us to demonstrate to clients and stakeholders that any company is keeping their personal data and information with the utmost care. This standard outlines a method for creating, implementing, running, monitoring, maintaining, and enhancing our ISMS. ISO 27001 is a collection of rules for managing infrastructure, primarily data centers, to guarantee that particular legal, technical, and physical regulations are followed in order to protect the confidentiality, integrity, and availability of data stored in the data centers. ISO/IEC 27001 to ISO/IEC 27007 are some of the standards for ISO 27001. ISO 27001 specifies an ISMS, including risk management process standards that may be used to select security measures that are appropriate for the business threats. ISO 27001 is the only information security standard for which enterprises may be certified by an independent auditor. This ensures that information security is managed in accordance with worldwide best practices, according to independent expert assurance.
- **ISO 27002:** This framework provides best-practice guidelines for implementing the ISO 27001 controls indicated in Annex A. It supports ISO 27001 and should be read in conjunction with it. This standard establishes guidance for information security standards and management practices in organizations. It entails selecting, implementing, operating, and managing controls while keeping the organization's information security risk environment in mind (s).
- **ISO 27005:** This endorses up the main concepts stated out in 27001. Its purpose is to give guidance for implementing information security using a risk-based approach. Knowledge of the ideas, models, procedures, and terminology provided in ISO/IEC 27001 and ISO/IEC 27002 is essential to fully comprehend ISO/IEC 27005. This standard is applicable to a wide range of organizations, including non-profits, government agencies, and commercial companies.
- **ISO 27032:** This is the international standard that specifically addresses cybersecurity. This Standard contains standards for safeguarding information outside of an organization's borders, such as through collaborations, partnerships, or other information-sharing arrangements with clients and suppliers.

4.4.2 PCI DSS

The objective of the PCI Security Standards Council is to improve worldwide payment account data security by producing standards and supporting services that promote education, awareness, and successful implementation among stakeholders. The Payment Card Industry Data Security Standard is abbreviated as PCI DSS. This is the standard that must be chosen by any organisation that takes payments through their payment gateway. Businesses that hold personal information about customers, such as their names and credit card numbers, must comply with this requirement. According to this compliance, the organization's technology should be current, and its system should be subjected to regular security assessments to guarantee that it is not vulnerable.

This standard was created by a group of card companies (American Express, Visa, MasterCard, JCB, and Discover). PCI DSS is a precise 12-requirement structure for merchants and other businesses to secure cardholder data that is kept, processed, and/or transmitted. The standard's comprehensive nature provides a wealth of security information – so much so that some employees in charge of cardholder data security may be unsure where to begin their compliance journey. The PCI Security Standards Council offers the Prioritized Approach below to help stakeholders understand where they may take action to decrease risk early in the compliance process. Although no one milestone in the Prioritized Approach can achieve full security or PCI DSS compliance, stakeholders can speed up the process of safeguarding cardholder data by following its principles. On the road to PCI DSS compliance, this Prioritized Approach presents six security milestones to enable merchants and other businesses gradually guard against the biggest risk factors and growing threats.

Prioritized Approach and its milestones are intended to provide the following benefits:

- Roadmap that an organization can use to address its risks in priority order
- Pragmatic approach that allows for “quick wins”
- Supports financial and operational planning
- Promotes objective and measurable progress indicators
- Helps promote consistency among assessors

This Prioritized Approach lays out a compliance road map depending on the risk of holding, processing, and/or transferring cardholder data. The roadmap aids acquirers in objectively measuring compliance actions and risk reduction by merchants, service providers, and others, as well as setting milestones and lowering the risk of cardholder data breaches earlier in the compliance process. Data from real breaches, as well as criticism from Qualified Security Assessors, forensic investigators, and the PCI Security Standards Council Board of Advisors, went into the development of the Prioritized Approach. It is not meant to be a replacement, quick fix, or stop-gap method to PCI DSS compliance, nor is it an obligatory one-size-fits-all framework that must be followed by every firm. The Prioritized Approach is suitable for merchants who undergo an on-site assessment. The Prioritized Approach includes six milestones. The matrix below summarizes the high-level goals and intentions of each milestone. Below maps the milestones to each of all twelve PCI DSS requirements and their sub-requirements.

- a. **Remove sensitive authentication data and limit data retention:** This milestone targets a key area of risk for entities that have been compromised. Remember – if sensitive authentication data and other cardholder data are not stored, the effects of a compromise will be greatly reduced. If you don't need it, don't store it.
- b. **Protect systems and networks, and be prepared to respond to a system breach:** This milestone targets controls for points of access to most compromises, and the processes for responding.
- c. **Secure payment card applications:** This milestone targets controls

for applications, application processes, and application servers. Weaknesses in these areas offer easy prey for compromising systems and obtaining access to cardholder data.

- d. **Monitor and control access to your systems:** Controls for this milestone allow you to detect the ‘who, what, when, and how’ concerning who is accessing your network and cardholder data environment.
- e. **Protect stored cardholder data:** For those organizations that have analyzed their business processes and determined that they must store Primary Account Numbers, Milestone Five targets key protection mechanisms for that stored data.
- f. **Finalize remaining compliance efforts:** This ensures all controls are in place. The intent of Milestone Six is to complete PCI DSS requirements, and to finalize all remaining related policies, procedures, and processes needed to protect the cardholder data environment.

4.4.3 HIPAA

The Health Insurance Portability and Accountability Act is abbreviated as HIPAA. It is the requirement that hospitals must adhere to in order to ensure that their patients’ personal information is adequately safeguarded and cannot be disclosed. To meet this level, the hospital must have a competent network security staff that handles all security events, have healthy quarterly security reports, and conduct all transactions in encrypted mode, among other things. This standard guarantees that the patient’s vital health-related information is kept secure, giving them peace of mind regarding their health. HIPAA is also known as the Kennedy–Kassebaum Act, and this standard was adopted in 1996 by the United States Congress.

Its goals are to make it simpler for patients to maintain their health insurance when they change employment, to preserve the confidentiality and security of health-care data, and to assist the health-care business in reducing administrative expenses. Title II of the Act is concerned with the security of health-care information. The HIPAA Privacy Rule governs how covered organizations use and disclose Protected Health Information (PHI) and protects individuals’ rights to know and control how their health information is used. PHI is defined as data that may be used to identify an individual, including demographic data. It can exist in any media and refer to an individual’s past, present, or future physical or mental health state, the provision of health care to the individual, or the payment for the provision of health care to the individual in the past, present, or future. Common identifiers like as a person’s name, address, date of birth, or Social Security Number are included in PHI.

Covered entities must not use or disclose PHI except:

- If the Privacy Rule permits or requires it.
- If an individual (or their representative) authorizes the disclosure of their information in writing.

Covered entities must disclose PHI in only two situations:

- To individuals (or their representatives) when they request access to their PHI.

- To HHS when it is undertaking a compliance investigation or review or enforcement action.

Covered entities are permitted but not required to use and disclose PHI without an individual's authorization:

- To the individual who is the subject of the information.
- For their own treatment, payment and health care operations activities.
- When informal permission has been obtained by asking the individual outright.
- As a result of, or "as incident to" an otherwise permitted use or disclosure (as long as the covered entity has adopted reasonable safeguards and the information shared is limited to the "minimum necessary").
- For 12 national priority purposes. Specific conditions or limitations apply to each public interest purpose.
- As part of a limited data set (i.e. when certain specified direct identifiers have been removed) for research, health care operations and public health purposes.

Information that cannot be used to identify an individual is not subject to any limitations on its use or dissemination. Covered entities must, among other things, maintain track of PHI disclosures, publish privacy policies and procedures, appoint a Privacy Official, and train all employees on applicable processes.

4.4.4 FINRA

The Financial Industry Regulatory Authority (FINRA) standard is designed to make a financial organization that handles money or engages in aggressive financial activity safe. Under this standard, the system is anticipated to be exceptionally secure, and several data security and user data protection procedures must be considered to comply. It is one of the most significant requirements that must be met by all financial institutions. FINRA plays an important role in maintaining the integrity of America's financial system at no cost to taxpayers. FINRA, which is regulated by the Securities and Exchange Commission, aims to protect investors against fraud and bad practices. Consider the case of the 77-year-old blind widow who was robbed just weeks after her husband died. Given her seriously disabled state, she had fully relied on her broker to manage her finances, but her broker took advantage of her. The broker made over 700 deals in over 200 different assets, resulting in a \$184,000 loss for the blind widow. FINRA stepped in to correct the situation. For churning the widow's account and engaging in excessive and improper trading, the broker was charged with securities fraud. FINRA's mission is to safeguard the investing public against fraud and bad practices by pursuing five important ways to enable a fair, balanced, inclusive market where everyone can invest with confidence.

4.4.5 GDPR

The General Data Protection Regulation is abbreviated as GDPR. It is a European government-defined standard that is concerned with the data protection of all users. The organisation in charge of compliance must

ensure that the user's data is safe and cannot be accessed without valid authorization under this criterion. As the name implies, this standard is primarily concerned with the security of a user's data so that they may feel secure sharing it with any entity that complies with the General Data Protection Regulation. GDPR is most likely the world's strictest privacy and security regulation.

Despite the fact that it was designed and enacted by the European Union (EU), it imposes duties on enterprises everywhere that target or collect data about EU citizens. On May 25, 2018, the regulation went into force. Those that break the GDPR's privacy and security regulations will face steep fines, with penalties reaching the tens of millions of euros. GDPR signals Europe's hard position on data privacy and security at a time when more individuals are committing their personal data to cloud services and data breaches are becoming more common. GDPR compliance is a scary concept, especially for small and medium-sized businesses, because the law is broad, far-reaching, and lacking in specifics (SMEs). First, even if you're not in the EU, the GDPR applies to you if you process the personal data of EU citizens or residents, or if you provide products or services to them. Second, the penalties for breaking the GDPR are quite severe. There are two levels of fines, the highest of which is €20 million or 4% of worldwide income (whichever is greater), plus data subjects have the right to seek damages compensation.

The GDPR defines an array of legal terms at length, some of the most important ones are:

- Personal data is any information that relates to an individual who can be directly or indirectly identified. Names and email addresses are obviously personal data. Location information, ethnicity, gender, biometric data, religious beliefs, web cookies, and political opinions can also be personal data. Pseudonymous data can also fall under the definition if it's relatively easy to ID someone from it.
- Data processing is any action performed on data, whether automated or manual.
- Data subject is the person whose data is processed. These are customers or site visitors.
- Data controller is the person who decides why and how personal data will be processed. If you're an owner or employee in an organization who handles data.
- Data processor is a third party that processes personal data on behalf of a data controller. The GDPR has special rules for these individuals and organizations. They could include cloud servers like Tresorit or email service providers like ProtonMail.

Check Your Progress 2

Note: a) Space is given below for writing your answer.

b) Compare your answers with the ones given at the end of this Unit.

How do you know a Cybersecurity standard is right for you? Describe ISO Standard.

.....

.....

.....

.....

.....

.....

.....

4.5 CYBERSECURITY POLICIES

4.5.1 Defining Cybersecurity Policy

This document establishes and documents an organization's declaration of intent, principles, and techniques for managing cybersecurity risks in order to achieve its strategic goals. A security policy is a written statement of how a corporation intends to safeguard its physical and information technology assets. Security policies are dynamic documents that are updated and revised when new technologies, vulnerabilities, and security requirements emerge. An acceptable usage policy may be included in a company's security policy. These indicate how the organisation intends to educate its staff about asset protection. They also include a description of how security measures will be implemented and enforced, as well as a method for assessing the policy's efficacy and making any modifications.

4.5.2 Importance of Security Policies

These rules are crucial because they safeguard an organization's physical and digital assets. They include all of the company's assets as well as potential dangers to those assets. Physical security rules are designed to safeguard a company's physical assets, such as buildings and equipment, including computers and other information technology. Data security rules safeguard intellectual property from expensive occurrences like as data breaches and leaks. Policies concerning physical security Buildings, cars, merchandise, and machinery are all protected by physical security rules of a company. IT equipment such as servers, computers, and hard drives are among these assets. Because physical devices hold firm data, protecting IT physical assets is very crucial. The information contained and handled by a physical IT asset is at danger if it is compromised. In this way, information security policies are dependent on physical security policies to keep company data safe. Physical security policies include the following information:

- Sensitive buildings, rooms and other areas of an organization
- Who is authorized to access, handle and move physical assets
- Procedures and other rules for accessing, monitoring and handling these assets; and

Individuals' responsibilities for the physical assets they access and handle. Physical assets are protected through security guards, entrance gates, and door and window locks. Physical assets are also protected using other, more high-tech means. A biometric verification system, for example, can be used to restrict access to a server room. Anyone entering the room would use a fingerprint scanner to confirm their identity.

Security policies for information. The Cybersecurity policies provide the following advantages.

- **Protect valuable assets:** These policies help ensure the confidentiality, integrity and availability -- known as the CIA triad of data. They are often used to protect sensitive customer data and personally identifiable information.
- **Guard reputations:** Data breaches and other information security incidents can negatively affect an organization's reputation.
- **Ensure compliance with legal and regulatory requirements:** Many legal requirements and regulations are aimed at security sensitive information. For example, Payment Card Industry Data Security Standard dictates how organizations handle consumer payment card information. Health Insurance Portability and Accountability Act details how companies handle protected health information. Violating these regulations can be costly.
- **Dictate the role of employees:** Every employee generates information that may pose a security risk. Security policies provide guidance on the conduct required to protect data and intellectual property. Identify third-party vulnerabilities. Some vulnerabilities stem from interactions with other organizations that may have different security standards. Security policies help identify these potential security gaps.

4.5.3 Types of security policies

Security policy types can be divided into three types based on the scope and purpose of the policy:

- **Organizational:** These policies are a master blueprint of the entire organization's security program.
- **System-specific:** A system-specific policy covers security procedures for an information system or network.
- **Issue-specific:** These policies target certain aspects of the larger organizational policy. Examples of issue-related security policies include the following:
 - Acceptable use policies define the rules and regulations for employee use of company assets.
 - Access control policies say which employees can access which resources
 - Change management policies provide procedures for changing IT assets so that adverse effects are minimized.
 - Disaster recovery policies ensure business continuity after a service disruption. These policies typically are enacted after the damage from an incident has occurred.

- Incident response policies define procedures for responding to a security breach or incident as it is happening.

4.5.4 Key Elements in a Security Policy

Some of the key elements of an organizational information security policy include the following:

- Statement of the purpose
- Statement that defines who the policy applies
- Statement of objectives, which usually encompasses the CIA triad
- Authority and access control policy that delineates who has access to which resource
- Data classification statement that divides data into categories of sensitivity the data covered can range from public information to information that could cause harm to the business or an individual if disclosed
- Data use statement that lays out how data at any level should be handled this includes specifying the data protection regulations, data backup requirements and network security standards for how data should be communicated, with encryption.
- Statement of the responsibilities and duties of employees and who will be responsible for overseeing and enforcing policy
- Security awareness training that instructs employees on security best practices -- this includes education on potential security threats, such as phishing, and computer security best practices for using company devices
- Effectiveness measurements that will be used to assess how well security policies are working and how improvements will be made.

4.5.5 Examples of Security Policies

Insider threat incidences caused by human error cost businesses an average of \$3.8 million each year — that's a lot of money! Improved cybersecurity rules (and their dissemination) can enable employees in better understanding how to keep data and apps secure. Here are some security policy examples to consider when you construct a mature security programme:

- An acceptable usage policy, or AUP, is a document that outlines the limits and procedures that employees who utilize organizational IT assets must agree to in order to have access to the business network or systems. It's common onboarding procedure for new workers, requiring them to read and sign the AUP before being given a network ID.
- The purpose of a data breach response policy is to explain how to handle an event and mitigate the impact on business operations and customers. Staff roles and duties in resolving an incident are often defined in this policy, as well as standards and metrics, incident reporting, remediation activities, and feedback channels.

- Disaster recovery plan is created as part of a wider business continuity strategy that incorporates advice from both the cybersecurity and IT teams. The CISO and designated teams will then administer the data breach response policy to handle the issue. The business continuity plan, on the other hand, is only launched if the incident has a severe impact on the organisation.
- Business continuity plan, or BCP, outlines how the company will operate in the event of an emergency and organizes actions across the board. Furthermore, BCP will operate in tandem with the disaster recovery plan to restore hardware, software, and data that are critical to business continuity.
- According to an IBM research, remote access policies, such as those used for remote work during COVID-19, raised data breach costs in the United States by \$137,000. Remote access policies can be implemented by companies to establish and specify processes for remotely accessing their internal networks. When scattered networks having the capacity to expand into insecure network locations, such as home networks or coffee shops, organisation require this strategy.
- Access control policy, or ACP, is a set of guidelines that governs user access, network access restrictions, and system software controls. Techniques for monitoring how systems are accessed and utilised, how access is deleted when an employee departs the business, and how unattended workstations should be protected are common additional supplemental features.

Check Your Progress 3

Note: a) Space is given below for writing your answer.

b) Compare your answers with the ones given at the end of this Unit.

Mention at least six examples of Security Policies.

4.6 LET US SUM UP

The cybersecurity standards function as a collection of policies that describe the procedures or approaches that must be used to maintain the system secure. Several cybersecurity standards are now available on the market, with several new standards scheduled to be released this year. Almost every higher-level organisation is required to follow the standards since they are the variables that secure the company's security.

4.7 CHECK YOUR PROGRESS: THE KEY

1. Definitions:

- **Policies:** Policies are high-level statements of management intent from an organization's executive leadership that are designed to influence decisions and guide the organization to achieve the desired outcomes. Policies are enforced by standards and further implemented by procedures to establish actionable and accountable requirements. Policies are a business decision, not a technical one.
- **Procedures:** Procedures are a documented set of steps necessary to perform a specific task or process in conformance with an applicable standard. Procedures help address the question of how the organization actually operationalizes a policy, standard or control. Without documented procedures, there can be defensible evidence of due care practices. Procedures are generally the responsibility of the process owner / asset custodian to build and maintain but are expected to include stakeholder oversight to ensure applicable compliance requirements are addressed.
- **Standard:** Standards are mandatory requirements regarding processes, actions and configurations that are designed to satisfy Control Objectives. Standards are intended to be granular and prescriptive to ensure systems, applications and processes are designed and operated to include appropriate cybersecurity and privacy protections.

2. A right-fit, mature cybersecurity standard is one where the processes, tools, and people are all aligned and working together so that the program is successful at mitigating risk. The correct Cyber standard has buy-in from executive leadership, but also has goals that are felt across the entire organization. There will always be risks and vulnerabilities that plague mature cybersecurity programs, but there are actionable and agreed upon plans in place that partners and vendors agree to when working with a mature cybersecurity program. The specifics of program maturity boil down to the cybersecurity model chosen and what is counted as mature for each model. Cybersecurity models also can outline the order in which different steps should happen to reach program maturity.

ISO 27000 is an international standard, created by the International Organization for Standardization (ISO) to highlight best practices for information security management systems. This cybersecurity model is more popular among organizations in the European Union, and focuses attention on the three main areas of a mature cybersecurity management program: people, processes, and technology. The recommendations of the ISO 27000 cybersecurity model is broken down into the following areas for security managers to use best practices to reach program maturity:

- Security risk assessment
- Security policy
- Asset management
- Human resources security
- Physical and environmental security
- Communications and operations management
- Access control
- Information systems acquisition, development, and maintenance
- Information security incident management
- Business continuity management

ISO 27000 guides organizations beyond the typical cybersecurity management practices to include greater security standards and protections. ISO 27000 includes management of critical physical and operational security measures, and is broken down into ISO 27000 Series to get more specific into the actual implementation and design of this cybersecurity model.

3. Some of the well-known Security Policies are

- **Acceptable use policy (AUP):** specifies the restrictions and practices that an employee using organizational IT assets must agree to in order to access the corporate network or systems. It is a standard onboarding policy for new employees, ensuring that they have read and signed the AUP before being granted a network ID.
- **Data breach response policy:** describes the process of handling an incident and remediating the impact on business operations and customers. This policy typically defines staff roles and responsibilities in handling an incident, standards and metrics, incident reporting, remediation efforts, and feedback mechanisms.
- **Disaster recovery plan:** is developed as part of the larger business continuity plan, which includes both cybersecurity and IT teams' recommendations. The CISO and assigned teams will then manage an incident through the data breach response policy. However, the business continuity plan is activated only when the incident has a significant impact on the organization.
- **Business continuity plan (BCP):** describes how the organization will operate in an emergency and coordinates efforts across the organization. Additionally, BCP will work in conjunction with the disaster recovery plan to restore hardware, applications, and data that are considered essential for business continuity.
- **Remote access policy:** Remote work during COVID-19 increased data breach costs in the United States by \$137,000. Organizations can implement a remote access policy that outlines and defines procedures to remotely access the organization's internal networks. Organizations require this policy when there

are dispersed networks with the ability to extend into unsecured network locations, such as home networks or coffee shops.

- **Access control policy (ACP)** defines the standards for user access, network access controls, and system software controls. Additional supplementary items often include techniques for monitoring how systems are accessed and used, how access is removed when an employee leaves the organization, and how unattended workstations should be secured.

